

INFORME DE DEFINICIÓN PROYECTO APT – FASE 1

Integrantes: Angel Muñoz, Jerson Reyes, Jason Sanchez.

Profesor: Rodrigo Alvarez

Asignatura: PTY4614 Capstone.

Carrera: Ingeniería en Informática.

Sede: San Bernardo.

1. Abstract / Resumen

Abstract

ComplianceAI is an innovative, privacy-by-design software platform created to help small and medium-sized enterprises (SMEs) evaluate and achieve compliance with the new Chilean Data Protection Law (Law No. 21.719). The system integrates a dynamic self-assessment engine with a local Natural Language Processing (NLP) model for the irreversible extraction and anonymization of Personally Identifiable Information (PII). By running AI models locally and applying strict cybersecurity measures (AES-256, TLS 1.3, and OWASP mitigation), the project ensures that sensitive data is never exposed to third-party APIs. This project demonstrates advanced capabilities in secure software architecture, agile project management, and automated quality assurance.

Resumen

ComplianceAI es una plataforma de software innovadora diseñada bajo el principio de privacidad por diseño, orientada a ayudar a las pequeñas y medianas empresas (pymes) a evaluar y alcanzar el cumplimiento de la nueva Ley de Protección de Datos de Chile (Ley N.º 21.719). El sistema integra un motor de autodiagnóstico dinámico con un modelo local de Procesamiento de Lenguaje Natural (NLP) para la extracción y anonimización irreversible de Información Personal Identificable (PII). Al ejecutar modelos de IA localmente y aplicar estrictas medidas de ciberseguridad (AES-256, TLS 1.3 y mitigación OWASP), el proyecto garantiza que los datos sensibles nunca se expongan a APIs de terceros. Este proyecto demuestra capacidades avanzadas en arquitectura de software segura, gestión ágil de proyectos y aseguramiento de calidad automatizado.

2. Descripción del Proyecto APT y Relevancia Laboral

ComplianceAI consiste en la construcción de una plataforma integral que permite a las organizaciones diagnosticar su nivel de madurez respecto a la privacidad de datos y aplicar rutas formativas automáticas para corregir sus brechas. El núcleo diferenciador del proyecto es su módulo de IA Local (Módulo 2), el cual procesa textos legales e identifica datos sensibles utilizando un motor NER (Reconocimiento de Entidades Nombradas) y Expresiones Regulares exclusivas para el formato chileno (RUT), anonimizándolos antes de guardarlos en la base de datos.

Relevancia para el campo laboral: La entrada en vigencia de la Ley N.º 21.719 ha generado una demanda urgente en la industria tecnológica por soluciones que garanticen la seguridad de la información. Este proyecto responde directamente a esta necesidad del mercado, integrando habilidades altamente demandadas en la actualidad: ingeniería de datos, ciberseguridad, prevención de vulnerabilidades en LLMs (Inteligencia Artificial) y desarrollo de arquitecturas *Cloud* seguras.

3. Relación con las Competencias del Perfil de Egreso

El proyecto ComplianceAI permite movilizar y aplicar de forma directa las competencias centrales del perfil de egreso:

- **Realizar pruebas de certificación:** Se diseñarán y aplicarán pruebas unitarias automatizadas (ej. *pytest* en CI/CD) orientadas a la seguridad, específicamente para mitigar ataques de *Prompt Injection* y asegurar que los motores de IA mantengan un 0% de fuga de PII, siguiendo estándares de la industria como OWASP.
- **Gestionar proyectos informáticos:** Como Product Owner (PO) del equipo, aplico metodologías ágiles para definir la visión del producto, priorizar el backlog, gestionar requerimientos (Épicas en Jira) y asegurar la entrega de valor iterativa.
- **Construir modelos de datos:** Se implementará un modelo de base de datos relacional escalable que soporta el registro inmutable de trazabilidad y la gestión de derechos ARCOP exigidos por la ley, garantizando la minimización de datos.
- **Desarrollar una solución de software:** El proyecto exige la integración de un Backend robusto (APIs REST con latencia < 500ms) estructurado bajo un modelo Clean Baseline, conectando motores NLP locales y bases de datos cifradas bajo un ecosistema de despliegue continuo.

4. Relación con mis Intereses Profesionales

En mi rol dentro del equipo como Product Owner y responsable de Backend/Arquitectura, el proyecto se alinea perfectamente con mi interés en el diseño de arquitecturas seguras y el desarrollo de APIs robustas. Me apasiona investigar cómo integrar motores NLP locales y bases de datos cifradas sin comprometer la privacidad del usuario. Además, liderar la visión del producto, priorizar el backlog y configurar los entornos de integración continua (CI/CD) me permite potenciar mis habilidades de liderazgo técnico y operaciones (DevOps), áreas en las que deseo especializarme profesionalmente.

5. Factibilidad del Proyecto

El proyecto es totalmente factible de realizarse en el tiempo asignado para la asignatura (Sprints distribuidos a lo largo del semestre) debido a los siguientes factores:

- **Recursos y Materiales:** Contamos con las herramientas necesarias a costo cero o mediante licencias académicas: Visual Studio Code, entornos Python, librerías *Open Source* para NLP (spaCy/ONNX), Jira para gestión y GitHub para el control de versiones.
- **Alcance Acotado (Scrum):** El uso de metodologías ágiles nos permite dividir el desarrollo en entregas funcionales quincenales, asegurando que siempre haya un producto base que mostrar en caso de atrasos.
- **Plan de Mitigación de Dificultades:** El mayor riesgo técnico es la "alucinación" de la IA o fallos en la detección de PII. Esto se ha mitigado arquitectónicamente al no depender de modelos generativos inestables, sino de motores extractivos locales (NER) combinados con expresiones regulares (Regex) rígidas y pruebas de seguridad automatizadas desde el Sprint 1.

6. Objetivos del Proyecto

Objetivo General:

Desarrollar una plataforma de software seguro orientada al cumplimiento normativo (Ley N.º 21.719) que integre motores de inteligencia artificial local para la extracción y anonimización de datos sensibles, garantizando la privacidad por diseño.

Objetivos Específicos:

1. Implementar un motor de autodiagnóstico dinámico que evalúe procesos y genere rutas formativas automáticas sin redundancias.
2. Construir un módulo de Procesamiento de Lenguaje Natural (NLP) de ejecución local para sanitizar PII (RUT, correos, nombres) con un 100% de precisión estructural, evitando integraciones con APIs externas.
3. Desarrollar una arquitectura Backend segura, aplicando cifrado avanzado (AES-256 / LTS 1.3) y superando pruebas automatizadas contra vulnerabilidades de inyección.

7. Propuesta Metodológica de Trabajo

El equipo adoptará el marco de trabajo **Scrum**, permitiendo un desarrollo incremental y adaptativo.

- **Roles:** El equipo está dividido en *Product Owner* (Backend/Arquitectura – mi rol), *Scrum Master* (Data/Seguridad), y *Developer Lead* (Frontend/UX/UI).
- **Gestión de Tareas:** Se utilizará Jira Software para mapear los requerimientos en 4 grandes Épicas que se trabajarán en paralelo.
- **Ciclo de Desarrollo:** Ejecutaremos Sprints de 1 a 2 semanas. Además, aplicaremos TDD (*Test-Driven Development*) para el ámbito de seguridad, escribiendo los casos de prueba de vulnerabilidades (ej. inyección de prompts) antes de integrar el modelo final.
- **Control de versiones:** Estructura de ramas (GitFlow) en GitHub con revisión por pares (*Pull Requests*) y validación de cobertura mediante CI/CD.

8. Plan de Trabajo (Hitos y Tareas Principales)

El siguiente plan resume mis responsabilidades directas dentro de los Sprints del proyecto:

Hito / Actividad (Rol: Data, QA & Scrum Master)	Recursos Requeridos	Duración	Facilitadores (+) y Obstaculizadores (-)
T-07: Sesiones bi semanales con Therion Labs para revisión de maquetas UI.	-	Transversal	(+) Medios de comunicaciones (Email). (-) Atrasos en desarrollo de maquetas..
Organización y priorización del Backlog (Épicas, historias de usuario y criterios de aceptación)	Jira Software, Backlog, Roadmap, reuniones de refinamiento.	Transversal	(+) Alinea al equipo con la visión del producto y permite entregar valor priorizado. (-) Riesgo de cambios de alcance o prioridades mal definidas.
Gestión del cronograma y seguimiento de Sprints (hitos, estimaciones y roadmap)	Jira Software, roadmap, milestones, actas de reunión, GitHub.	Transversal	(+) Mejora la visibilidad de avances y permite anticipar retrasos. (-) Dependencia de estimaciones precisas y disponibilidad del equipo.

9. Propuesta de Evidencias

Para asegurar que las actividades declaradas cumplan con los indicadores de calidad esperados, el proyecto generará las siguientes evidencias tangibles a lo largo del semestre:

1. **Tablero Ágil Documentado:** Exportación y métricas del tablero de Jira, demostrando la gestión del *Backlog*, cumplimiento de Épicas y estimaciones de historias de usuario.
2. **Repositorio y Pipeline CI/CD:** Acceso al repositorio en GitHub evidenciando la estructura modular, los *commits* semánticos y la ejecución exitosa de flujos de trabajo (*Actions*) de *testing* automático.
3. **Reportes de Pruebas de Seguridad:** Registros de salida de *pytest* donde se evidencie una tasa del 0% de fuga de PII frente a los 13 vectores de ataque estructurados de *Prompt Injection* (OWASP).
4. **Contrato de Interfaz (OpenAPI):** Documentación Swagger desplegada y funcional que detalla las interacciones del Backend y la latencia del sistema.
5. **Entorno Piloto Desplegado:** Plataforma accesible en la nube (Staging) validada por usuarios reales mediante métricas de usabilidad (SUS).

10. Conclusiones

The development of ComplianceAI represents a timely and viable technological response to the regulatory challenge introduced by Chile's Law No. 21.719. The project demonstrates that small and medium-sized enterprises can access high-level tools to assess and improve their data protection compliance without compromising privacy or operational efficiency. This is achieved through a privacy-by-design architecture that integrates a dynamic self-assessment engine with a local Natural Language Processing module for the irreversible extraction and anonymization of Personally Identifiable Information.

From a technical perspective, the combination of NER engines, regular expressions tailored to Chilean formats—such as the RUT—AES-256 encryption, TLS 1.3, and OWASP-aligned mitigations significantly reduces the risk of data leaks and avoids dependence on third-party APIs. In addition, the incorporation of automated testing into CI/CD pipelines, the use of TDD, and coverage validation strengthen software quality and enable early verification of the system's resilience against vulnerabilities such as prompt injection.

Ultimately, ComplianceAI reaffirms the role of the computer engineer as a professional capable of articulating technical, regulatory, and ethical knowledge. The project shows that security, privacy, and innovation can be integrated into a single solution, delivering concrete value to organizations and contributing to a more mature and responsible data protection culture.

11. Reflexión

This project, ComplianceAI, represents a significant challenge and a profound learning opportunity. It has pushed us to think beyond pure code and consider the broader context of software engineering: its ethical, legal, and business implications. Translating complex regulations into a functional and user-friendly application is a powerful exercise in abstraction and problem-solving. The initial planning phase has reinforced the importance of a well-

defined scope and iterative methodologies like Scrumban to manage complexity and uncertainty. We have learned that a successful project is not just about technical prowess but also about clear communication, stakeholder management, and a deep understanding of the problem being solved. This experience is invaluable, as it is shaping our professional identity as engineers capable of creating technology that is not only innovative but also responsible and trustworthy. It is a clear reflection of the engineer's role as a bridge between technical possibility and societal need.